INSTITUTO TECNOLOGICO SUPERIOR PROGRESO

CARRERA:
INGENIERIA EN SISTEMAS COMPUTACIONALES

GRADO Y GRUPO:
9no - Grupo 1

MATERIA:
PENTESTING

TAREA:
ENSAYO: IMPLICACIONES ÉTICAS Y LEGALES DEL ESCANEO DE VULNERABILIDADES

FECHA DE ENTREGA:
29 de octubre de 2026

ESTUDIANTE:
Carlos Eduardo Valencia Hernández

DOCENTE:
MARTÍNEZ GARCÍA HOLZEN



Contenido

1. Introducción y Delimitación Técnica del Escaneo de Redes 3
2. Marco Deontológico y Deber Ético del Auditor de Seguridad 5
2.1. Códigos de Ética de Asociaciones Internacionales de Computación 5
2.2. Principios Bioéticos Aplicados y Divulgación Responsable 5
3. Mecánica Técnica y Riesgos Operativos Colaterales del Escaneo 7
3.1. Vectores de Inestabilidad Provocados por el Escaneo 7
4. Marco Jurídico Nacional: Legislación Mexicana y el Código Penal Federal 9
4.1. Análisis Exegético de los Artículos 211 bis 1 al 211 bis 7 del CPF 9
4.2. El Escaneo frente a la Teoría del Delito: ¿Acto Preparatorio o Tentativa Punible? 10
5. Marco Jurídico Internacional y Derecho Comparado 11
5.1. El Convenio de Budapest sobre la Ciberdelincuencia (STE n.º 185) 11
5.2. Legislación Estadounidense: CFAA y el Caso Paradigmático Scott Moulton (2000) 11
5.3. Tabla Comparativa de Marcos Regulatorios Internacionales 12
6. Protocolos de Blindaje Jurídico y Metodología Defensiva en Pentesting 13
6.1. Los Cuatro Instrumentos de Salvaguarda Jurídica Obligatoria 13
6.2. Modelo de Cláusula de Autorización para Auditorías de Red 13
7. Análisis de Casos Reales y Dilemas Éticos Contemporáneos 14
7.1. El Caso del Estudiante 'White Hat' No Solicitado 14
7.2. Programas de Bug Bounty y Cláusulas de 'Safe Harbor' 14
7.3. Escaneo Masivo Global de Internet (Shodan, Censys y ZMap) 14
8. Conclusiones 15
9. Referencias Bibliográficas 16



Boulevard Tecnológico de Progreso SN x 62, Progreso, Yucatán,
C.P. 97320 Tel. 969 934 3023 E-mail: dir01_dprogreso@tecnm.mx
www.progreso.tecnm.mx



1. Introducción y Delimitación Técnica del Escaneo de Redes

En el ecosistema de la seguridad informática contemporánea, la evaluación diagnóstica de infraestructuras digitales representa una necesidad imperativa para mitigar incidentes de brechas de datos y ataques cibernéticos. Dentro de las fases metodológicas de una auditoría de seguridad o prueba de penetración (penetration testing), el escaneo de puertos y de vulnerabilidades constituye el punto de inflexión donde el analista abandona la pasividad del reconocimiento de fuentes abiertas (OSINT) para entablar una comunicación activa y directa con los activos informáticos del objetivo.

Desde una perspectiva netamente computacional, escanear no es un proceso pasivo ni aséptico. Consiste en la inyección deliberada de paquetes de red estructurados —tales como paquetes TCP SYN, FIN, NULL, XMAS, datagramas UDP y peticiones con payloads a nivel de aplicación— dirigidos contra los 65,535 puertos lógicos de un host o subred. La respuesta devuelta por los sockets del sistema receptor permite al escáner determinar qué puertos se encuentran abiertos, qué demonios o servicios responden detrás de ellos, sus versiones exactas y, en el caso de herramientas especializadas como OpenVAS o Nessus, la presencia de fallas lógicas conocidas mediante pruebas de vulnerabilidad en red (NVTs).

No obstante, este proceso técnico encierra una profunda dualidad: las mismas secuencias de sondeo que un administrador o auditor ético emplea para detectar configuraciones erróneas y parchar servicios desactualizados son exactamente las mismas que un ciberdelincuente despliega para cartografiar la superficie de ataque y seleccionar el vector óptimo de intrusión. A nivel de paquetes de red, un paquete TCP SYN no transporta en sus cabeceras la intención moral de quien lo originó.

Tesis fundamental del ensayo: La tesis central que sustenta el presente ensayo sostiene que el escaneo de redes y vulnerabilidades no puede ser concebido como una actividad neutral o exenta de consecuencias jurídicas y éticas. Su legitimidad no deriva de la herramienta tecnológica utilizada, sino de la concurrencia indispensable de tres factores: el consentimiento explícito y documentado del propietario legítimo de los activos, la competencia técnica para evitar daños operativos colaterales, y la estricta subordinación de la práctica a los marcos normativos vigentes.





Figura 1: El rol del auditor de seguridad (White Hat) operando bajo estrictos principios éticos y salvaguardas legales durante evaluaciones de infraestructura.

Comprender la dimensión ética del escaneo exige trascender la fascinación por el dominio técnico de las herramientas de intrusión. Para el estudiante de ingeniería y el profesional de la ciberseguridad, cada comando ejecutado en la consola de comandos representa una decisión deontológica que impacta derechos fundamentales como la privacidad, la confidencialidad y la continuidad operativa de organizaciones y personas. El propósito de este trabajo es desentrañar los fundamentos normativos, los límites éticos y los instrumentos jurídicos que transforman un potencial delito informático en un ejercicio legítimo y profesional de auditoría.



2. Marco Deontológico y Deber Ético del Auditor de Seguridad

La delimitación ética en el ámbito del pentesting suele estructurarse en la literatura mediante la metáfora de los sombreros. Los hackers de 'sombrero blanco' (White Hat) operan con fines defensivos y bajo consentimiento explícito; los de 'sombrero negro' (Black Hat) persiguen lucro ilícito, espionaje o sabotaje; mientras que los de 'sombrero gris' (Grey Hat) se desenvuelven en un terreno ambiguo, vulnerando sistemas sin autorización previa bajo el argumento de una pretendida benevolencia para alertar a los administradores.

Desde el rigor de la deontología informática profesional, la figura del Grey Hat o 'hacker benevolente no solicitado' carece de sustento ético. Acceder a un sistema informático ajeno o probar sus cerraduras digitales sin autorización vulnera la autonomía del propietario y transgrede los principios fundamentales de la práctica profesional de la ingeniería.

2.1. Códigos de Ética de Asociaciones Internacionales de Computación

Los principales organismos rectores de la profesión tecnológica han formulado preceptos categóricos que norman la conducta de los profesionales en seguridad informática:

Código de Ética y Conducta Profesional de la ACM: En su Sección 1.2 ('Evitar el daño'), el Código de Ética de la ACM estipula que los profesionales de la computación deben abstenerse de realizar acciones que menoscaben la estabilidad, confidencialidad o disponibilidad de sistemas ajenos. Asimismo, en su Sección 2.8 determina de forma inequívoca que solo se debe acceder a recursos de cómputo y comunicación cuando se cuente con la debida autorización o cuando una causa justificada de bien público lo ampare estrictamente.

Código de Ética de EC-Council: El organismo emisor de la certificación Certified Ethical Hacker (CEH) exige a sus miembros comprometerse bajo juramento a preservar la confidencialidad de la información descubierta, no divulgar vulnerabilidades sin el acuerdo expreso del cliente, y rechazar categóricamente cualquier prueba invasiva que pueda causar denegación de servicio o degradación operativa.

Consorcio Internacional de Certificación de Seguridad (ISC)²: Establece en sus cuatro cánones primarios el deber ineludible de 'Proteger a la sociedad, a la comunidad y a la infraestructura', así como 'Actuar con honorabilidad, honestidad, justicia, responsabilidad y apego a la ley'.

Código de Ética del IEEE: El Instituto de Ingenieros Eléctricos y Electrónicos compromete formalmente a sus agremiados a mantener el más alto estándar de integridad moral, evitando conflictos de interés, respetando la privacidad de terceros y rechazando cualquier práctica que comprometa la infraestructura tecnológica crítica sin la explícita delegación de autoridad.

2.2. Principios Bioéticos Aplicados y Divulgación Responsable

La bioética proporciona marcos de referencia sumamente valiosos para evaluar la práctica del escaneo. Destaca el Principio de No Maleficencia (Primum non nocere: ante todo, no dañar). En el contexto del escaneo, este principio obliga al pentester a calibrar milimétricamente la intensidad de sus





herramientas para impedir que ráfagas de paquetes saturen conmutadores, cortafuegos o servidores en producción.

Un dilema ético recurrente radica en la gestión de las vulnerabilidades descubiertas. Existen dos posturas contrapuestas: la divulgación total (Full Disclosure), donde el investigador publica abiertamente los detalles del fallo y el código de explotación en foros públicos para forzar al fabricante a corregirlo rápidamente; y la Divulgación Coordinada y Responsable (Coordinated Vulnerability Disclosure - CVD), amparada en estándares internacionales como ISO/IEC 29147. En la CVD, el auditor notifica de manera privada y detallada al desarrollador u organización, otorgándole un plazo prudencial (habitualmente 90 días) para desplegar un parche de seguridad antes de que la información se haga del dominio público.

La perspectiva utilitarista y el imperativo categórico kantiano convergen en que la seguridad colectiva no puede construirse sobre la base de vulnerar unilateralmente la propiedad privada ajena. Actuar éticamente en ciberseguridad implica reconocer que el fin de proteger un sistema no justifica los medios ilícitos de allanarlo sin consentimiento.

> *"El acceso a sistemas informáticos sin autorización formal, incluso con la alegada intención de evaluar su resiliencia o alertar sobre sus debilidades, constituye una violación flagrante a la autonomía de las partes y una transgresión de la deontología profesional que desacredita a la disciplina del pentesting."*
>
> **— Comité Ético del EC-Council (2023)**



Boulevard Tecnológico de Progreso SN x 62, Progreso, Yucatán,
C.P. 97320 Tel. 969 934 3023 E-mail: dir01_dprogreso@tecnm.mx
www.progreso.tecnm.mx



3. Mecánica Técnica y Riesgos Operativos Colaterales del Escaneo

Quienes conciben el escaneo como una actividad inofensiva argumentan con frecuencia que 'enviar un paquete SYN no altera ningún dato'. Esta premisa técnica es errónea e ignora la arquitectura interna de los sistemas operativos modernos y los dispositivos intermedios de red. Un escaneo intensivo o mal configurado puede desencadenar fallas catastróficas en la disponibilidad de servicios productivos.

```
[root@darkstar ~]#
[root@darkstar ~]# nmap -PN sS -O Scanme.Nmap.Org

Starting Nmap 5.21 ( http://nmap.org ) at 2010-04-01 11:19 IDT
Nmap scan report for Scanme.Nmap.Org (64.13.134.52)
Host is up (0.18s latency).
rDNS record for 64.13.134.52: scanme.nmap.org
Not shown: 993 filtered ports
PORT      STATE  SERVICE
25/tcp    closed smtp
53/tcp    open   domain
70/tcp    closed gopher
80/tcp    open   http
113/tcp   closed auth
8009/tcp  open   ajp13
31337/tcp closed Elite
Device type: general purpose
Running: Linux 2.6.X
OS details: Linux 2.6.15 - 2.6.26

OS detection performed. Please report any incorrect results at http://nmap.org/submit/
Nmap done: 1 IP address (1 host up) scanned in 16.99 seconds
[root@darkstar ~]#
```

Figura 2: Ejecución técnica de escaneo de puertos mediante Nmap reflejando sondeo activo de puertos y enumeración de servicios en red.

3.1. Vectores de Inestabilidad Provocados por el Escaneo

1. Agotamiento de tablas de estado en Firewalls e IDS/IPS: Los cortafuegos modernos mantienen una tabla en memoria RAM donde registran el estado de cada conexión bidireccional (Stateful Inspection Table). Cuando un escáner como Masscan o Nmap lanza decenas de miles de paquetes SYN por segundo hacia un rango de direcciones, la tabla de estados del firewall se satura rápidamente. Como resultado, el cortafuegos descarta conexiones legítimas de usuarios o colapsa por agotamiento de memoria, provocando una denegación de servicio (DoS) involuntaria.

2. Colapso de dispositivos embebidos, IoT e infraestructura industrial (SCADA): A diferencia de servidores robustos con kernels Linux actualizados, los controladores lógicos programables (PLCs), sistemas de supervisión y adquisición de datos (SCADA) e instrumentos médicos conectados a la red operan con pilas TCP/IP embebidas sumamente frágiles. El envío de paquetes con banderas atípicas (como escaneos NULL o FIN) o solicitudes HTTP malformadas puede congelar el dispositivo físico, requiriendo reinicios manuales e interrumpiendo procesos industriales críticos.

3. Sobrecarga de procesamiento y degradación de ancho de banda: El escaneo masivo consume ciclos de CPU del servidor auditado, el cual debe responder con paquetes RST a cada puerto cerrado o generar procesos 'fork' de demonios de red (ej. sendmail, sshd, ftpd) para negociar los banners de bienvenida. Si el ancho de banda o los recursos de cómputo del objetivo son modestos, la saturación degrada inmediatamente la experiencia del usuario final.

4. Desviación de recursos defensivos y falsas alarmas: Un escaneo activo detona cientos de firmas de alarma en los Centros de Operaciones de Seguridad (SOC) y Sistemas de Prevención de Intrusos (IPS). Esto





obliga al personal de respuesta a incidentes a movilizar horas de guardia, aislar segmentos de red y ejecutar protocolos de emergencia bajo la sospecha de una intrusión inminente, lo que genera costos financieros reales y distrae la atención defensiva de amenazas verdaderas.

5. Implicación de terceros mediante técnicas de evasión e IP Spoofing: La manipulación de banderas TCP (como en los escaneos de tipo Zombie o Idle Scan con IP spoofing) introduce variables de riesgo adicionales. Utilizar hosts intermedios sin consentimiento como reflectores de paquetes para enmascarar el origen del escáner involucra a terceros inocentes en una interacción potencialmente hostil, violando la soberanía de sus recursos de red y exponiéndolos a bloqueos o investigaciones judiciales indebidas.



Boulevard Tecnológico de Progreso SN x 62, Progreso, Yucatán,
C.P. 97320 Tel. 969 934 3023 E-mail: dir01_dprogreso@tecnm.mx
www.progreso.tecnm.mx

4. Marco Jurídico Nacional: Legislación Mexicana y el Código Penal Federal

En los Estados Unidos Mexicanos, la regulación en materia de ciberdelincuencia y delitos cometidos a través de medios electrónicos se encuentra principalmente codificada en el Código Penal Federal (CPF). Específicamente, el Título Noveno, denominado 'Revelación de Secretos y Acceso Ilícito a Sistemas y Equipos de Informática', tipifica en su Capítulo II las conductas delictivas relacionadas con el uso no autorizado de tecnologías de información.



Figura 3: La ley penal como límite ineludible: tipificación del acceso ilícito y protección de sistemas informáticos en la legislación nacional.

4.1. Análisis Exegético de los Artículos 211 bis 1 al 211 bis 7 del CPF

El marco penal mexicano establece un esquema gradual de penalidades en función del daño causado, la confidencialidad de la información vulnerada y la naturaleza del sujeto pasivo (particulares, gobierno o sistema financiero):

Artículo 211 bis 1 (Tipo básico contra particulares): Este precepto constituye la base de los delitos informáticos para particulares. Establece que al que sin autorización conozca o copie información contenida en sistemas o equipos protegidos por algún mecanismo de seguridad, se le impondrán de 3 meses a 1 año de prisión y de 50 a 150 días multa. Si además modifica, destruye o provoca pérdida de información, la sanción se eleva de 6 meses a 2 años de prisión y de 100 a 300 días multa.

Artículo 211 bis 2 (Sistemas del Estado y Seguridad Pública): Contempla severas agravantes cuando el sistema vulnerado pertenece al Estado o a instituciones de Seguridad Pública. Conocer, obtener o copiar información de seguridad pública protegida por mecanismos de seguridad amerita penas de 4 a 10 años



de prisión y de 500 a 1,000 días multa, las cuales se duplican si la conducta obstaculiza la procuración o impartición de justicia.

Artículo 211 bis 3 (Abuso de accesos autorizados en el Estado): Castiga con penas de 2 a 8 años de prisión a las personas que, contando con autorización legítima para acceder a sistemas del Estado, abusen de sus privilegios para destruir o copiar información con fines ilícitos.

Artículos 211 bis 4 y 211 bis 5 (Protección al Sistema Financiero): Establecen penas privativas de la libertad de hasta 10 años de prisión para quienes accedan sin autorización a equipos de instituciones integrantes del Sistema Financiero Mexicano o utilicen indebidamente la información contenida en ellos.

4.2. El Escaneo frente a la Teoría del Delito: ¿Acto Preparatorio o Tentativa Punible?

Un debate dogmático recurrente entre juristas e informáticos forenses en México radica en determinar si el escaneo de puertos por sí mismo consuma el delito previsto en el Artículo 211 bis 1. Para que se actualice dicho artículo, el tipo penal exige 'conocer o copiar información' en un sistema 'protegido por algún mecanismo de seguridad'.

Aunque el simple envío de paquetes SYN recopila banners técnicos de versiones y no bases de datos confidenciales, la jurisprudencia y la doctrina procesal penal contemplan la figura de los actos preparatorios y la tentativa punible (Artículo 12 del CPF). Si un peritaje forense demuestra que el escaneo de puertos fue inmediatamente seguido de intentos de inyección de código, explotación de vulnerabilidades o que causó la caída de un servicio, el escaneo es catalogado como el acto preparatorio indispensable de la conducta delictiva, perdiendo cualquier presunción de inocencia.

Asimismo, la Ley Federal de Protección de Datos Personales en Posesión de los Particulares (LFPDPPP) impone severas sanciones a organizaciones que permitan el acceso indebido a datos sensibles de ciudadanos. Si durante un escaneo no autorizado un analista descubre una base de datos expuesta sin contraseña y la visualiza o descarga, incurre simultáneamente en un delito penal tipificado en el CPF y en una violación a la normativa federal de privacidad.



5. Marco Jurídico Internacional y Derecho Comparado

Dado el carácter transfronterizo de las redes informáticas, las pruebas de seguridad que cruzan fronteras soberanas se rigen por instrumentos internacionales y legislaciones foráneas con alcance extraterritorial.



Figura 4: Sede del Consejo de Europa en Estrasburgo, cuna del Convenio de Budapest sobre Ciberdelincuencia, estándar global en derecho informático.

5.1. El Convenio de Budapest sobre la Ciberdelincuencia (STE n.º 185)

Redactado por el Consejo de Europa y ratificado por más de 65 naciones (con México en calidad de Estado observador y cooperante), el Convenio de Budapest representa el tratado multilateral vinculante más relevante en materia de delitos cibernéticos:

Artículo 2 (Acceso Ilícito): Obliga a los Estados parte a tipificar como delito el acceso deliberado y sin autorización a la totalidad o a una parte de un sistema informático vulnerando medidas de seguridad.

Artículos 4 y 5 (Interferencia en Datos y Sistemas): Sanciona la alteración, borrado, deterioro o supresión ilícita de datos informáticos, así como el entorpecimiento grave de sistemas.

Artículo 6 (Abuso de Dispositivos y Herramientas Duales): Contempla la penalización de la producción, venta o facilitación de dispositivos o programas concebidos primordialmente para cometer delitos. Este artículo ha generado intensas controversias respecto a herramientas de doble uso (dual-use tools) como Nmap o Metasploit, reafirmando que su posesión es legítima únicamente para fines educativos y defensivos autorizados.

5.2. Legislación Estadounidense: CFAA y el Caso Paradigmático Scott Moulton (2000)



En los Estados Unidos, la principal norma penal contra delitos informáticos es la Computer Fraud and Abuse Act (CFAA, 18 U.S.C. § 1030). La historia de la ciberseguridad registra un litigio judicial fundacional sobre el escaneo de puertos: el caso Scott Moulton v. VC3, Inc. (2000).

Scott Moulton, contratista de soporte tecnológico para el Centro 911 del Condado de Cherokee en Georgia, fue contratado para interconectar redes con la policía de la ciudad vecina de Canton. Ante la preocupación de que dicha interconexión expusiera al centro 911 a riesgos, Moulton ejecutó escaneos de puertos contra los servidores de la empresa VC3 (proveedora de la ciudad) sin contar con autorización previa. VC3 detectó las sondas y presentó una denuncia ante la Oficina de Investigaciones de Georgia (GBI). Moulton fue arrestado bajo cargos de intento criminal de allanamiento informático, perdió su contrato comercial y enfrentó años de litigio federal.

Aunque el juez federal Thomas Thrash determinó finalmente que el escaneo de puertos por sí solo no violaba la CFAA al no haber causado un daño material demostrable en la disponibilidad de los datos, el caso sentó un precedente histórico imborrable: incluso en ausencia de dolo malicioso, realizar un escaneo sin contrato previo firmado puede destruir la reputación profesional, causar arrestos y acarrear costos legales astronómicos.

5.3. Tabla Comparativa de Marcos Regulatorios Internacionales

Jurisdicción / Norma	Figura Tipificada	Penalidades Previstas	Criterio sobre Escaneo de Red
México (Código Penal Federal Art. 211 bis 1)	Acceso ilícito a sistemas protegidos y daño a datos.	3 meses a 2 años de prisión (particulares); hasta 10 años en seguridad pública.	Considerado acto preparatorio de intrusión si carece de contrato firmado.
Convenio de Budapest (Consejo de Europa STE 185)	Acceso ilícito, interferencia de datos y abuso de dispositivos.	Definidas por cada Estado parte (generalmente penas privativas de libertad).	Tipifica acceso no autorizado; exige demostrar dolo e intencionalidad.
EE. UU. (Computer Fraud & Abuse Act - CFAA)	Acceso no autorizado y exceso de autorización (18 U.S.C. § 1030).	Hasta 10 años de prisión por infracción y resarcimiento de daños civiles.	Jurisprudencia Moulton/Van Buren exige probar daño patrimonial o alteración.
Unión Europea (Directiva 2013/40/UE)	Ataques contra sistemas de información y obstaculización ilícita.	Penas máximas de al menos 2 a 5 años de prisión según la gravedad.	El sondeo pasivo no se castiga, pero la interrupción o colapso sí es punible.





6. Protocolos de Blindaje Jurídico y Metodología Defensiva en Pentesting

Para transformar una actividad que técnicamente coincide con un ciberataque en una auditoría profesional legalmente blindada, los estándares internacionales como NIST SP 800-115, OSSTMM (Open Source Security Testing Methodology Manual) y PTES (Penetration Testing Execution Standard) exigen la formalización de cuatro instrumentos jurídicos previos a cualquier ejecución técnica:

6.1. Los Cuatro Instrumentos de Salvaguarda Jurídica Obligatoria

1. Reglas de Compromiso (Rules of Engagement - RoE): Establecen el perímetro exacto de la prueba. Detallan de forma exhaustiva las direcciones IP, nombres de dominio y rangos CIDR autorizados, excluyendo explícitamente sistemas de terceros alojados en la misma nube. Fijan las ventanas horarias de escaneo (preferentemente fines de semana o noches fuera del horario operativo), limitan la tasa de transferencia de paquetes (--max-rate) y prohíben expresamente ataques de denegación de servicio (DoS) o fuerza bruta desmedida.

2. Carta de Autorización y Consentimiento Expreso (Permission to Test): Conocida comúnmente en el argot profesional como 'Get Out of Jail Free Card'. Es una carta oficial membretada, firmada con poder notarial o representación jurídica por el Director General (CEO), Director de Seguridad de la Información (CISO) o apoderado legal de la organización auditada. Este documento faculta expresamente al equipo auditor a realizar pruebas de intrusión y sirve como prueba fehaciente ante proveedores de nube (AWS, Azure) o autoridades judiciales en caso de falsas alarmas.

3. Acuerdo de Confidencialidad y No Divulgación (NDA - Non-Disclosure Agreement): Garantiza que cualquier información, contraseña, configuración o fallo de seguridad descubierto durante el escaneo sea clasificado bajo estricto secreto profesional, prohibiendo su difusión a terceros y protegiendo la propiedad intelectual de la organización evaluada.

4. Procedimiento de Escalamiento de Emergencia y Contactos Clave: Define una matriz de contactos de emergencia disponible 24/7 (personal de infraestructura, base de datos y redes) y establece que, si un escaneo provoca lentitud o inestabilidad en algún servicio productivo, el pentester suspenderá inmediatamente la ejecución técnica y notificará de inmediato al enlace técnico designado.

6.2. Modelo de Cláusula de Autorización para Auditorías de Red

> *"Por medio de la presente, la empresa [Razón Social de la Organización], a través de su Representante Legal debidamente facultado, otorga autorización expresa e informada al equipo de auditoría para ejecutar pruebas técnicas de escaneo de puertos y evaluación de vulnerabilidades sobre los activos informáticos comprendidos en el rango [Direcciones IP / Dominios Autorizados]. Las presentes actividades se desarrollarán bajo los lineamientos metodológicos de las Reglas de Compromiso suscritas y con exención de responsabilidad penal derivada del ejercicio legítimo de la auditoría contratada."*
>
> **— Cláusula Modelo de Carta de Autorización (Safe Harbor / RoE)**





7. Análisis de Casos Reales y Dilemas Éticos Contemporáneos

La teoría ética y legal adquiere sentido cuando se analiza a la luz de situaciones reales que enfrentan cotidianamente los profesionales de tecnologías de información y estudiantes de sistemas computacionales:

7.1. El Caso del Estudiante 'White Hat' No Solicitado

Un escenario frecuente involucra a estudiantes entusiastas de ciberseguridad que deciden ejecutar Nmap u OpenVAS contra servidores de su universidad, alcaldía municipal o una clínica médica local, identificando bases de datos expuestas o servicios obsoletos. Con la intención de 'ayudar', envían un correo a la dirección de soporte reportando los hallazgos.

Lejos de recibir una felicitación, en la inmensa mayoría de los casos las organizaciones responden presentando una denuncia formal ante el Ministerio Público o la Policía Cibernética por tentativa de acceso indebido (Art. 211 bis 1 del CPF). Las instituciones perciben el aviso como un acto de intimidación o potencial extorsión. La lección ética es contundente: jamás se debe auditar un sistema ajeno sin un contrato previo o sin que la entidad cuente con un programa oficial de divulgación de vulnerabilidades.

7.2. Programas de Bug Bounty y Cláusulas de 'Safe Harbor'

Para conciliar la necesidad de descubrir fallas con la protección legal de los investigadores, la industria global ha consolidado las plataformas de Bug Bounty (tales como HackerOne, Bugcrowd o Intigriti). En estos ecosistemas, las empresas publican una política pública de Safe Harbor (puerto seguro) donde establecen:

1. Las aplicaciones y dominios exactos que los investigadores tienen permiso explícito para escanear.
2. El compromiso vinculante de la empresa de no emprender acciones legales penales ni civiles contra quienes respeten las reglas del programa.
3. La prohibición expresa de alterar datos de usuarios reales o generar ataques de denegación de servicio.
4. La recompensa económica o reconocimiento formal por cada falla reportada bajo el principio de divulgación coordinada.

7.3. Escaneo Masivo Global de Internet (Shodan, Censys y ZMap)

Plataformas como Shodan, Censys o Shadowserver ejecutan de manera permanente escaneos masivos sobre todo el espacio de direccionamiento IPv4 de Internet. Sus creadores defienden la práctica argumentando fines de investigación estadística global y cartografía del ciberespacio. No obstante, este escaneo permanente genera fricciones sobre soberanía digital, ya que gobiernos y entidades privadas ven sondeados sus activos sin haber otorgado consentimiento, facilitando que ciberdelincuentes utilicen esos mismos motores de búsqueda para localizar objetivos vulnerables sin necesidad de emitir un solo paquete propio.





8. Conclusiones

Al desarrollar este ensayo sobre las implicaciones éticas y legales del escaneo de vulnerabilidades entendí con total claridad que en el campo de la seguridad informática la línea que separa a un auditor profesional de un ciberdelincuente no la define el tipo de software que ejecutamos en la terminal, sino la existencia de una autorización legal formal y el respeto absoluto a los límites acordados. Antes solía ver al escaneo de puertos como una simple rutina técnica inofensiva, una especie de sondeo exploratorio para ver qué servicios estaban levantados; sin embargo, al profundizar en el marco legal mexicano y en casos como el de Scott Moulton me di cuenta del enorme peso que tiene enviar paquetes hacia sistemas ajenos sin contar con un contrato previo.

Comprendí que el Código Penal Federal tipifica con gran severidad el acceso no autorizado y que la legislación no juzga el conocimiento técnico, sino la intención y el impacto que provocamos. Descubrí también que un escáner mal configurado puede tirar servicios productivos o saturar equipos industriales delicados, convirtiendo una supuesta ayuda en un daño real de denegación de servicio. Por ello, la lección más valiosa que me llevo es que antes de lanzar una sola consulta con Nmap u OpenVAS debemos contar con nuestras Reglas de Compromiso, un Acuerdo de Confidencialidad y una Carta de Autorización debidamente firmada.

Como futuro ingeniero en sistemas egresado del Tecnológico de Progreso, tengo muy claro que el verdadero valor de nuestra profesión radica en ejercerla con madurez, ética y apego a la ley. Saber encontrar fallas de seguridad es una habilidad técnica poderosa, pero saber hacerlo dentro del marco jurídico para proteger a las personas y a las organizaciones es lo que realmente nos distingue como profesionales íntegros y confiables.





9. Referencias Bibliográficas

Association for Computing Machinery [ACM]. (2018). ACM Code of Ethics and Professional Conduct. ACM. https://www.acm.org/code-of-ethics

Cámara de Diputados del H. Congreso de la Unión. (2024). Código Penal Federal: Título Noveno, Capítulo II, Delitos en Materia de Acceso Ilícito a Sistemas y Equipos de Informática (Artículos 211 bis 1 al 211 bis 7). Diario Oficial de la Federación. https://www.diputados.gob.mx/LeyesBiblio/pdf/CPF.pdf

Consejo de Europa. (2001). Convenio sobre la Ciberdelincuencia (Convenio de Budapest, Serie de Tratados Europeos Núm. 185). Consejo de Europa. https://www.coe.int/en/web/cybercrime/the-budapest-convention

EC-Council. (2023). Certified Ethical Hacker (CEH) Code of Ethics. International Council of E-Commerce Consultants. https://www.eccouncil.org/code-of-ethics/

Institute of Electrical and Electronics Engineers [IEEE]. (2020). IEEE Code of Ethics. IEEE Policies, Section 7. https://www.ieee.org/about/corporate/governance/p7-8.html

International Organization for Standardization [ISO]. (2020). Information technology — Security techniques — Vulnerability disclosure (ISO/IEC Standard No. 29147:2020). ISO. https://www.iso.org/standard/72225.html

National Institute of Standards and Technology [NIST]. (2008). Technical Guide to Information Security Testing and Assessment (NIST Special Publication 800-115). U.S. Department of Commerce. https://doi.org/10.6028/NIST.SP.800-115

U.S. District Court for the Northern District of Georgia. (2000). Moulton v. VC3, Inc., Civil Action File No. 1:00-CV-305-TWT, 2000 U.S. Dist. LEXIS 19912. United States District Court.



Boulevard Tecnológico de Progreso SN x 62, Progreso, Yucatán,
C.P. 97320 Tel. 969 934 3023 E-mail: dir01_dprogreso@tecnm.mx
www.progreso.tecnm.mx